



P: 866.420.4573 ext. 801
W: SynED.org
E: info@syned.org

API Modification Request

SkillBit Game Platform Integration

Prepared by synED for SkillBit (formerly MetaCTF)

Document Version: 1.0

Date: May 10, 2026

Owner: Scott Young, synED Technical Lead — scott@listentosee.com

Subject: Proposed API and SSO modifications to support the 2026-2027 program cycle

Distribution: SkillBit Engineering & Product; synED Engineering

Executive Summary

synED is preparing the Cyber-Guild coach dashboard to support a recurring 12-month program cycle. Five operational changes — annual student release and re-pickup across coaches, region-aware operations, assistant-coach access, persistent student access to the game platform through a dedicated companion application, and rotating authentication credentials — drive a focused set of modifications to SkillBit's API and SSO endpoint.

This document defines seven modification requests. Four are blocking for the 2026-2027 cycle launch; three are non-blocking but recommended.

Blocking

- MR-1: Coach reassignment endpoint to support students moving between coaches at cycle boundaries.
- MR-2: Migrate the SSO identity claim from email to syned_user_id so coaches and the forthcoming student companion app enter through SkillBit's single SSO interface without requiring email alignment between systems.
- MR-3: Multi-key authentication with kid rotation for zero-downtime key rotation and per-relying-party isolation.
- MR-4: Configurable SkillBit-side session length to support persistent ("always on") student access.

Non-Blocking

- MR-5: Region context (syned_region_id) on TeamCreate and echoes on UserResponse / TeamResponse.
- MR-6: Optional deep-link parameters on the SSO payload.
- MR-7: Optional acting_user_id field on write endpoints for audit attribution.

synED preserves SkillBit's single SSO entry point throughout. Both coach and student traffic continues to enter through one interface; the changes adjust what is in the JWT, not where it is sent.

Background & Context

For the 2026-2027 program cycle, synED is extending the Cyber-Guild coach dashboard to support an annual release and claim cycle in which students may move from one coach to another between program years; region-aware operations spanning coaches, competitors, teams, and shared pools; an assistant-coach role permitting up to two assistants per head coach, sharing the head coach's roster context; and a dedicated student-facing companion application that provides persistent access to the SkillBit game platform.

The companion application integrates with the coach dashboard for student identity verification and account provisioning, then mints SSO JWTs and redirects students into SkillBit through the same SSO interface used by coaches. To make this work without coupling SkillBit accounts to email addresses managed independently by the dashboard, the SSO identity contract must move off email and onto a stable identifier — the syned_user_id that already exists for every provisioned user on both sides.

In parallel, synED is rotating its credential model to match the pattern already used for its CyberNuggets partner SSO: multiple concurrently active keys, identified by kid, rotated independently per relying party. This isolates the dashboard and the student companion app from each other and aligns with synED's internal security standards.

Unified SSO Contract (Reference)

Across all SSO traffic — coach launches from the coach dashboard and student launches from the student companion app — synED proposes a single JWT shape signed against SkillBit's existing /connect endpoint. This contract underpins MR-2, MR-3, MR-4, and MR-6.

Target JWT Payload

```
{
  "syned_user_id": "<uuid>",    // authoritative identity (MR-2)
  "iat": 1715300000,
  "exp": 1715300600,
  "target_path": "/...",        // optional (MR-6)
  "kid": "<key id>"             // in JWT header; selects secret (MR-3)
}
```

SkillBit resolves the user by syned_user_id against the mapping already populated during provisioning via POST /integrations/syned/v1/users. The same /connect endpoint serves both coach and student traffic. Each relying party signs with its own registered kid; SkillBit's verifier selects the matching shared secret.

MR-1. Coach Reassignment Endpoint

Status: BLOCKING — required for 2026-2027 cycle rollover

Definition

A new API endpoint that updates the syned_coach_user_id assignment for an existing user without requiring the user to be deleted and recreated.

Rationale

synED is introducing an annual release-and-claim cycle in which a student may move from one coach to another at program-year boundaries. Today there is no SkillBit endpoint that reassigns a user from one coach to another. The dashboard cannot reflect a coach change on the SkillBit side without a delete-and-recreate operation, which would discard the student's historical progress, prior challenge solves, Flash CTF participation, and account continuity. Preserving that history is critical to the educational and competition value of the platform.

Proposed Technical Approach

New endpoint: POST /integrations/syned/v1/users/reassign_coach

Request body:

```
{
  "syned_user_id": "string",           // existing user (required)
  "new_syned_coach_user_id": "string"  // target coach (required)
}
```

Response: 200 OK with the updated UserResponse body. Error responses: 404 if syned_user_id is unknown; 401 if the calling key is not authorized; 409 if the user has active team memberships under the prior coach that have not been cleared.

Implementation Note

Team memberships in SkillBit are scoped to the prior coach's teams. synED's dashboard will call POST /users/delete_assignment for any active team memberships before invoking the reassignment, then call POST /users/assign_team to a team owned by the new coach after the reassignment completes. SkillBit does not need to migrate team memberships server-side.

Backward Compatibility

Fully additive. No effect on existing flows or schemas.

MR-2. SSO Identity Claim Migration to syned_user_id

Status: BLOCKING — gates student companion app launch

Definition

Update SkillBit's /connect SSO endpoint to accept syned_user_id as the authoritative identity claim within the signed JWT, replacing email as the primary identifier across both coach and student SSO traffic.

Rationale

Today the SSO JWT carries { email, firstName, lastName }. This creates a hard dependency on email alignment between SkillBit and the coach dashboard: if a coach or student updates an email on one side, identity resolution breaks until the change is propagated to the other side. With the introduction of a student companion app that may use parent email addresses for minors and transition to student email at age 18, plus normal coach email churn, this alignment requirement becomes operationally untenable.

The persistent, immutable syned_user_id is the natural identity primitive. It already exists for every provisioned user on both sides (populated at POST /users time) and is independent of email lifecycle. Migrating identity resolution to syned_user_id eliminates the alignment requirement entirely while preserving SkillBit's single SSO interface.

Proposed Technical Approach

Target SSO JWT payload (shared by coach and student traffic):

```
{
  "syned_user_id": "string",    // authoritative identity
  "iat": 1715300000,
  "exp": 1715300600,
  "kid": "string"              // see MR-3
}
```

SkillBit's /connect resolves the user by syned_user_id against its existing mapping. The same endpoint serves both coach and student traffic. Email may remain in the payload as optional, ignored display metadata during a transition window and then be dropped from the contract.

Backward Compatibility & Transition Plan

Run both schemes concurrently for a 60-day transition window. synED's dashboard switches to syned_user_id payloads behind a feature flag at coordinated cutover. SkillBit accepts both shapes during the window and emits structured logs identifying which path each request takes. At the end of the window, the email-keyed path is disabled on the SkillBit side.

Pre-Provisioning Expectation

All SSO traffic is preceded by POST /integrations/syned/v1/users for provisioning. SkillBit should return 401 with a distinguishable error code if a /connect request references a syned_user_id it does not recognize, rather than auto-provisioning. synED requests written confirmation that current behavior matches this expectation (see Open Questions).

MR-3. Multi-Key Authentication with kid Rotation

Status: BLOCKING — required before MR-2 launch to support multi-relying-party isolation

Definition

Replace single-secret authentication on both the bearer-token API flow and the SSO JWT flow with multi-key authentication keyed by a kid (Key ID). Multiple keys are concurrently active with independent expiration, enabling zero-downtime rotation and per-relying-party isolation.

Rationale

synED's internal standard for partner integrations is rotatable keys with overlap windows; the CyberNuggets partner SSO already implements this pattern. The current MetaCTF integration uses a single static bearer (GAME_PLATFORM_API_TOKEN) and a single static HS256 SSO secret (GAME_PLATFORM_SSO_KEY). Compromise of either forces a coordinated cutover window with downtime risk. Additionally, the coach dashboard and the student companion app must hold independent SSO signing keys so their blast radii are isolated — a compromise of the student app's key should not require rotating the dashboard's key, and vice versa.

Proposed Technical Approach

SkillBit issues each registered relying party one or more (kid, shared secret) pairs. For SSO JWTs, the kid is included in the JWT header; SkillBit's verifier looks up the secret by kid. For bearer API calls, the kid is supplied in an X-API-Key-Id request header alongside the existing Authorization: Bearer <token>; SkillBit's verifier matches the token to the registered secret for that kid.

Each key carries metadata visible to the registered relying party:

```
{
  "kid": "string",
  "status": "active" | "retiring" | "revoked",
  "created_at": "iso8601",
  "expires_at": "iso8601",
  "rotated_at": "iso8601 | null"
}
```

Verification accepts any key with status active or retiring. synED proposes a 90-day key life with a 14-day retiring overlap window as the default cadence.

Initial Relying-Party Registrations at Go-Live

- Coach dashboard — one bearer kid for API access; one SSO kid for coach launches.
- Student companion app — one SSO kid for student launches; no bearer API access.

Rotation Operations

A self-service rotation UI on the SkillBit side is preferred (mirroring how synED operates its own CyberNuggets SSO Management UI). If a self-service surface is not available at launch, a ticketed rotation path with a same-business-day SLA is acceptable.

Backward Compatibility

The current single-key model continues to function as a single registered kid until synED rotates. No coordinated cutover required for initial rollout — registering a kid for the existing keys preserves all current behavior.

MR-4. Configurable SkillBit-Side Session Length

Status: BLOCKING — required for student companion app launch

Definition

After a successful /connect landing, SkillBit's user session persists for a configurable interval. synED requests a default of 12 hours and a maximum of 24 hours.

Rationale

The student companion app provides persistent ("always on") access to the game platform. If SkillBit sessions expire too aggressively, students are forced back through the SSO mint mid-challenge, breaking

the experience and degrading the educational value of long-form challenge work. Coaches benefit from the same change during extended classroom and competition sessions.

Proposed Technical Approach

Two options, in order of preference:

Option A – Configured per registered relying party

Each registered kid carries a `session_ttl_seconds` value set during registration; sessions established via JWTs signed with that kid honor the configured TTL. This is operationally simple and centralizes policy in the relying-party registration record.

Option B – Claim on the inbound JWT

The dashboard or companion app sets a `session_ttl_seconds` claim on each SSO JWT, bounded by a per-kid maximum enforced server-side. More flexible per request, but adds a claim to the contract and a server-side enforcement check.

synED recommends Option A.

Backward Compatibility

Existing behavior preserved if `session_ttl_seconds` is unset on the registered kid.

MR-5. Region Context on Team Operations

Status: NON-BLOCKING – target: 2026-2027 cycle

Definition

Add `syned_region_id` as an optional field on `TeamCreate`, and echo `syned_region_id` on `UserResponse` and `TeamResponse`.

Rationale

`UserCreate` already accepts `syned_region_id`. synED is normalizing region context across coaches, competitors, and teams to drive region-scoped roster management, region-aware analytics, and region-gated student pools during the release-and-claim cycle. Mirroring region on team creation closes the current asymmetry between user and team provisioning. Echoing the field on user and team responses enables drift detection between synED and SkillBit records during periodic reconciliation.

Proposed Technical Approach

`TeamCreate` adds:

```
{
  ...,
  "syned_region_id": "string"  // optional, nullable
}
```

`UserResponse` and `TeamResponse` add:

```
{
```

```
...,
  "syned_region_id": "string | null"
}
```

No changes to UserCreate, which already accepts the field.

Backward Compatibility

Fully additive. Existing clients ignore the new response field; existing TeamCreate payloads without syned_region_id continue to succeed.

MR-6. SSO Deep-Link Parameters

Status: OPTIONAL — nice-to-have

Definition

Allow the SSO JWT to carry a target_path (or equivalent) claim that directs the user to a specific challenge, monthly Flash CTF event, or competition on landing.

Rationale

Coaches frequently share specific challenges and Flash CTF events with their students. A deep-link parameter on the SSO payload lets the coach dashboard and student companion app drop a user directly into the intended SkillBit context after the SSO handshake, rather than landing on the SkillBit home page and requiring the student to navigate. Materially improves the experience for coach-shared links in class and via parent communications.

Proposed Technical Approach

Add an optional target_path claim on the SSO JWT, validated server-side as a relative path on SkillBit's domain (no absolute URLs accepted, to prevent open-redirect classes of issue). On successful SSO, SkillBit redirects to target_path after establishing the session.

```
{
  "syned_user_id": "string",
  "target_path": "/challenges/123",  // optional, relative path only
  "iat": ..., "exp": ..., "kid": "..."
}
```

Backward Compatibility

Additive and optional. Sessions without target_path continue to land on the existing default page.

MR-7. Acting User Attribution for Assistant Coaches

Status: OPTIONAL — nice-to-have

Definition

Add an optional `acting_user_id` field to write endpoints — POST `/users`, POST `/teams`, POST `/users/assign_team`, POST `/users/delete_assignment`, POST `/teams/delete`, POST `/users/reassign_coach` — recording the dashboard user who initiated the action when it differs from the head coach whose context owns the record.

Rationale

synED is introducing an assistant-coach role permitting up to two assistants per head coach. Assistants act within the head coach's roster context. All write traffic to SkillBit will continue to be attributed to the head coach's `syned_coach_user_id` — that is the correct ownership model. For audit and incident-review purposes, mirroring the underlying acting user on the SkillBit side provides defense-in-depth alongside the dashboard's own activity log. This is not blocking; the dashboard's audit log captures the attribution independently.

Proposed Technical Approach

Add `acting_user_id` (optional string) to write endpoint request bodies. SkillBit logs this value alongside the request but does not use it for authorization or data scoping. If absent, SkillBit logs the head coach as both owner and actor.

Backward Compatibility

Additive and optional.

Sequencing & Rollout Recommendation

synED's preferred sequence for SkillBit's implementation, accommodating dependencies between the requests:

- MR-3 (multi-key authentication) lands first. Every other change is safer with a key set that survives a leak, and the rotation pattern is independent of the SSO payload changes.
- MR-2 (SSO identity migration) and MR-4 (configurable session length) land together, with the 60-day dual-acceptance window for MR-2 beginning at deploy. synED will switch its dashboard and stand up its student companion app during the window.
- MR-1 (coach reassignment) lands before the 2026-2027 cycle rollover so the release-and-claim flow can complete end-to-end on both sides of the integration.
- MR-5, MR-6, and MR-7 land opportunistically; none block cycle launch.

synED is available for a joint technical review session to walk through the JWT contract change (MR-2) and the multi-key registration model (MR-3) before SkillBit's implementation begins. synED can provide reference implementations of the dashboard-side JWT signing and key management flows on request.

Open Questions for SkillBit

- What is SkillBit's current behavior when /connect receives a JWT for an email or syned_user_id that has not been pre-provisioned via POST /users — auto-create, error, or other? Confirmation expected before MR-2 implementation begins.
- What are the current rate limits on /integrations/syned/v1/*? The addition of the reassignment endpoint and increased SSO traffic from persistent student access may shift load patterns.
- Is self-service key rotation through a SkillBit admin UI on the roadmap, or will rotations remain ticketed? Either is workable; the answer informs synED's internal rotation cadence policy.
- Does SkillBit have a preferred contract version-bumping convention (e.g., /integrations/syned/v2/*) for any of these changes, or are all changes intended to land on v1 as additive?
- Is SkillBit able to provide structured logs to synED covering SSO success and failure events during the 60-day MR-2 transition window, including which identity path (email vs. syned_user_id) each request took?

Contact

synED Technical Lead

Scott Young — scott@listentosee.com

General

info@syned.org | 866.420.4573 ext. 801

Mailing Address

2060-D Avenida de Los Arboles, Suite 771

Thousand Oaks, CA 91362